

Detalles del hallazgo.

Durante la fase de enumeración de la superficie de ataque TLS, se identificó que el servidor permite la negociación de los siguientes protocolos: TLS v1.0, TLS v1.1 y TLS v1.2. Aunque TLS 1.2 actualmente considerado seguro cuando están correctamente configurado, la habilitación simultánea de versiones obsoletas introduce un riesgo crítico debido a la posibilidad de ataques de degradación (protocol downgrade attacks). Adicionalmente, se identificaron cipher suites asociadas a modos de cifrado vulnerables, lo que habilita las siguientes debilidades:

- **BEAST (Browser Exploit Against SSL/TLS):** afecta TLS 1.0 con cifrados CBC bajo ciertos escenarios de ataque MITM.
- **LUCKY13:** vulnerabilidad basada en ataques de temporización contra implementaciones CBC en TLS.
- **SWEET32:** asociada al uso de cifrados de bloque de 64 bits (ej. 3DES), permitiendo recuperación parcial de texto plano tras grandes volúmenes de tráfico.

Impacto potencial.

El impacto de estas vulnerabilidades se centra exclusivamente en la pérdida de Confidencialidad de la información transmitida entre el usuario y el servidor.

1. Interceptación y descifrado de sesiones (Hijacking).

El mayor peligro es el robo de cookies de sesión.

- Escenario: un atacante en la misma red (como un Wi-Fi público) utiliza técnicas de BEAST o LUCKY13 para recuperar fragmentos del tráfico cifrado.
- Consecuencia: si el atacante obtiene el testigo de sesión (Session Token), puede suplantar la identidad del usuario sin necesidad de conocer su contraseña, accediendo a su cuenta y datos personales dentro de la aplicación web.

2. Exposición de credenciales y datos sensibles.

Si la aplicación transmite formularios de login o datos personales (DNI, tarjetas, correos) mediante estos protocolos débiles:

- Escenario: mediante SWEET32, tras una captura prolongada de tráfico, un atacante podría reconstruir partes del texto plano.
- Consecuencia: fuga de información sensible que viaja en el cuerpo de las peticiones HTTP, comprometiendo la privacidad del usuario y la integridad de la base de datos de clientes si se capturan credenciales administrativas.

3. Degradación de la postura de seguridad (Downgrade Attacks).

La presencia de estas vulnerabilidades permite ataques de "Downgrade".

- Escenario: un atacante puede forzar a que el navegador de la víctima y el servidor se comuniquen usando el protocolo más débil disponible (ej. TLS 1.0) para luego aplicar los exploits mencionados.
- Consecuencia: anula las protecciones de protocolos más modernos (como TLS 1.2 o 1.3) que el servidor sí podría tener configurados, dejando la conexión desprotegida.

Técnica utilizada.

Metodología:

- La identificación del hallazgo se realizó mediante la ejecución de la herramienta testssl.sh, la cual evaluó:
 - Enumeración de protocolos soportados a través de escaneo TLS.

Análisis de Seguridad de Aplicaciones Web:

COOPERATIVA DE TRANSPORTADORES DEL HUILA LIMITADA

Fecha: 25/03/2026

- Análisis de negociación de cipher suites.
- Identificación de cifrados CBC y bloques de 64 bits.
- Validación de soporte para SSL v3 y TLS legacy.
- Correlación con vulnerabilidades criptográficas documentadas públicamente.
- Se verificó la capacidad del servidor para negociar versiones vulnerables sin restricciones, confirmando la exposición efectiva.

Recomendaciones de mitigación.

- Deshabilitar protocolos obsoletos: TLS 1.0, TLS 1.1.
- Permitir únicamente: TLS 1.2 (con configuración endurecida) y TLS 1.3.
- Deshabilitar cipher suites débiles:
 - Eliminar 3DES (mitiga SWEET32).
 - Eliminar cifrados CBC inseguros cuando sea posible.
 - Priorizar suites con: ECDHE, AES-GCM, ChaCha20-Poly1305.

Evidencias.

```
Testing protocols via sockets except I
SSLv2      not offered (OK)
SSLv3      not offered (OK)
TLS 1      offered (deprecated)
TLS 1.1    offered (deprecated)
TLS 1.2    offered (OK)
TLS 1.3    not offered and downgraded
```

Ilustración 6. Protocolos TLS obsoletos identificados en el sitio <https://cootranshuila.sigemas.com/#!/Login>

```
Testing vulnerabilities
Heartbleed (CVE-2014-0160)      not vulnerable (OK), no heartbeat extension
CCS (CVE-2014-0224)            not vulnerable (OK)
Ticketbleed (CVE-2016-9244), experiment. not vulnerable (OK), no session ticket extension
ROBOT                          not vulnerable (OK)
Secure Renegotiation (RFC 5746) supported (OK)
Secure Client-Initiated Renegotiation not vulnerable (OK)
CRIME, TLS (CVE-2012-4929)      not vulnerable (OK)
BREACH (CVE-2013-3587)         no gzip/deflate/compress/br HTTP compression (OK) - only supplied "/" tested
POODLE, SSL (CVE-2014-3566)     not vulnerable (OK), no SSLv3 support
TLS_FALLBACK_SCSV (RFC 7507)   Check failed, unexpected result, run testssl -Z --debug=1 and look at /tmp/testssl.J8eoQn/*tls_
SWEET32 (CVE-2016-2183, CVE-2016-6329) VULNERABLE, uses 64 bit block ciphers
FREAK (CVE-2015-0204)          not vulnerable (OK)
DROWN (CVE-2016-0800, CVE-2016-0703) not vulnerable on this host and port (OK)
make sure you don't use this certificate elsewhere with SSLv2 enabled services, see
https://search.censys.io/search?resource=hosts&virtual_hosts=INCLUDE8q-CAFE7C1E815C17FB7D3B38EE0
A1D
LOGJAM (CVE-2015-4000), experimental common prime with 2048 bits detected: RFC7919/ffdhe2048 (2048 bits),
but no DH EXPORT ciphers
BEAST (CVE-2011-3389)          TLS1: ECDHE-RSA-AES256-SHA ECDHE-RSA-AES128-SHA AES256-SHA AES128-SHA DES-CBC3-SHA
VULNERABLE -- but also supports higher protocols TLSv1.1 TLSv1.2 (likely mitigated)
LUCKY13 (CVE-2013-0169), experimental potentially VULNERABLE, uses obsolete cipher block chaining ciphers with TLS, see server prefs.
Winshock (CVE-2014-6321), experimental not vulnerable (OK) - CAMELLIA or ECDHE_RSA GCM ciphers found
RC4 (CVE-2013-2566, CVE-2015-2808) no RC4 ciphers detected (OK)
```

Ilustración 6. Vulnerabilidades identificadas protocolo SSL/TLS en el sitio <https://cootranshuila.sigemas.com/#!/Login>